Purview Audit → SIEM Integration — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Purview Audit → SIEM Integration 5

The problem . . . 5

The solution . . . 5

What you get . . . 5

Approach . . . 5

Boundaries . . . 6

The bottom line . . . 6

1. Solution Overview — Purview Audit → SIEM Integration 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

The export stack this solution configures . . . 7

What you can control . . . 8

Naming convention (used in every doc and script) . . . 8

Limitations (be honest with buyers) . . . 8

The standard deployment model . . . 9

2. Requirements Guide — Purview Audit → SIEM Integration 9

2.1 Unified audit logging already enabled (assumed input) . . . 9

2.2 Export path decided (native connector vs. Management API vs. Graph) . . . 10

2.3 Entra app registration for the Management Activity API (if using it) . . . 10

2.4 Certificate app-only authentication (no secrets in code) . . . 10

2.5 Export/read roles (least-privilege) . . . 10

2.6 SIEM ingestion endpoint and its identity . . . 11

2.7 Detection use-cases and retention target (from SOC / compliance) . . . 11

2.8 A pilot scope and change window . . . 11

Global Requirements — Microsoft Purview Solutions 11

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Purview Audit → SIEM Integration 14

Step 1 — Assess the current export surface (Assess) . . . 14

Step 2 — Choose the export path and design coverage (Design) . . . 14

Step 3 — Stand up the app identity (Configure) . . . 15
Step 4 — Start the pilot content subscription (Configure → Pilot) . . . 15
Step 5 — Confirm blobs are flowing to the SIEM (Pilot) . . . 16
Step 6 — Reconcile SIEM ingestion against the source (Validate) . . . 16
Step 7 — Expand to full workload coverage (Expand) . . . 16
Step 8 — Operationalize and monitor the pipeline (Expand) . . . 17
5. Testing & Validation Guide — Purview Audit → SIEM Integration 17
Test 1 — Source is on (precondition) . . . 17
Test 2 — App identity authenticates app-only . . . 17
Test 3 — Pilot subscription is enabled . . . 18
Test 4 — Webhook validation handshake (push delivery only) . . . 18
Test 5 — Blobs available at the API for benign test activity . . . 18
Test 6 — End-to-end: events land in the SIEM . . . 18
Test 7 — Reconciliation: no silent loss . . . 18
Test 8 — Detection use-cases fire . . . 19
Test 9 — Full-coverage regression (after Expand) . . . 19
Test 10 — Drift check (scheduled) . . . 19
6. Troubleshooting — Purview Audit → SIEM Integration 19
`AUDSIEM-Discovery.ps1` reports `UnifiedAuditLogIngestionEnabled = False` . . . 20
The app identity won't authenticate app-only . . . 20
`subscriptions/start` fails the webhook validation handshake . . . 20
Blobs are available at the API but absent in the SIEM . . . 20
Reconciliation shows a material shortfall (source ■ SIEM) . . . 21
A native connector and a manual subscription are double-ingesting . . . 21
A webhook subscription "just stopped" after working . . . 21
The Graph Audit Log Query API isn't available / behaves differently . . . 21
DLP events aren't exporting . . . 22
`Connect-ExchangeOnline` / `Connect-IPPSSession` / `Connect-MgGraph` fails . . . 22
When to escalate beyond this solution . . . 22
7. Best Practices — Purview Audit → SIEM Integration 22
Path selection . . . 22
Identity & secrets . . . 23
Delivery reliability . . . 23
Reconcile, always . . . 23
Coverage & cost . . . 23
Governance & boundaries . . . 24

8. Deliverables Summary — Purview Audit → SIEM Integration 24
What you receive 24
Documents 24
PowerShell tools (5) 25
Outcomes 26
Boundaries 26
Appendix A — PowerShell Scripts 28

Executive Summary — Purview Audit → SIEM Integration

The problem

Microsoft Purview's unified audit log records who did what across the Microsoft 365 estate — but by default that signal stays **trapped in the portal**. The SOC can't correlate it with identity, endpoint, and network telemetry; can't build detections or alerts on it; and can't retain it past the audit store's window. An audit trail nobody's SIEM can see is a compliance gap and a detection blind spot. And the dangerous failure isn't "no data" — it's **silent partial loss**: a subscription stops, a webhook expires, a content type was never subscribed, and detections quietly go dark for months.

The solution

A complete, self-guided build of the **audit-to-SIEM pipeline**. It exports the unified audit log into your SIEM via the **Office 365 Management Activity API** (content subscriptions, push webhook or poll), the newer **Microsoft Graph Audit Log Query API**, or a **native connector** (Microsoft Sentinel, the Splunk Add-on, vendor connectors) — piloted on one content type, then **reconciled against the source audit log** to prove nothing is lost, then expanded to full workload coverage. Five safe-by-default PowerShell tools (read-only or `-WhatIf` until you commit; certificate app-only auth, no secrets) do the assessment, subscription configuration, blob validation, reconciliation, and pipeline reporting.

What you get

- **The right export path** — native connector, Management Activity API, or Graph query API — chosen for

your SIEM and tenant, not by default.

- **A least-privilege app identity** — certificate app-only, `ActivityFeed.Read` (`ReadDlp` for DLP),

admin-consented — with no secret in code.

- **Content subscriptions per workload** — Entra, Exchange, SharePoint, General, DLP — piloted one at a

time then expanded, mapped to the SOC's detection use-cases.

- **Proof it's lossless** — reconciliation of SIEM ingestion against the source audit log, so silent

partial loss surfaces as a gate, not a missed alert.

- **A monitored pipeline** — a stopped subscription, an expired webhook, or a lapsed certificate is a

first-class alert, because a dark feed blinds the SOC.

Approach

Delivery follows a disciplined, reversible model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — starting one content type end-to-end into the SIEM and reconciling it clean before expanding, with pass/fail gates and documented rollback (stop the subscription; the source audit log is never touched).

Boundaries

This solution builds the **pipeline**; enabling and configuring audit itself (ingestion, Premium high-value events, retention) is the companion **Purview Audit** solution — no export path can ship what audit isn't capturing, and **audit is not retroactive**. Export surface and limits are **licensing-/tenant-dependent and evolving** (Management API bandwidth, Graph query API availability, which native connectors exist) — cited or flagged **"verify your licensing/tenant,"** never assumed. **Detection content is the SOC's; retention adequacy, legal-hold, and regulatory determinations are deferred to compliance, records, privacy, and legal.**

The bottom line

Audit signal **out of the portal and into the SIEM** — reliably, least-privilege, and reconciled — so an incident finds **answers in your SIEM, not gaps**.

1. Solution Overview — Purview Audit → SIEM Integration

What this solution is

Microsoft Purview's unified audit log holds the record of who did what across Exchange, SharePoint, OneDrive, Teams, Entra ID, DLP, and more — but by default that signal stays **trapped in the portal**. Your SOC can't correlate it with the rest of the estate, can't build detections on it, can't alert on it, and can't retain it past the audit store's window. This solution builds the **pipeline** that gets that signal out: it stands up continuous export of unified audit + activity data from Microsoft Purview into your **SIEM** — via the **Office 365 Management Activity API** (content subscriptions, optionally push-delivered by webhook) and/or the newer **Microsoft Graph Audit Log Query API**, or a **native connector** where one exists — then pilots it on one content type, validates end-to-end that no events are being dropped, and expands to full workload coverage. It uses only the **Microsoft Purview portal**, **Exchange Online / Security & Compliance PowerShell**, **Microsoft Graph**, and the **Management Activity API** — no third-party tooling beyond your SIEM's own connector.

> ***Scope boundary — this is the *integration/pipeline*, not audit configuration itself.*** *Confirming and enabling unified audit logging, Audit Premium high-value events, retention policies, and building investigation runbooks is the companion* ***Purview Audit (Standard & Premium)*** *solution. This solution assumes audit is *on* and focuses end-to-end on* ***getting it into the SIEM reliably*** *— the app identity, subscriptions, delivery, connector, and the reconciliation that proves nothing is lost.*

Why this matters

- **Audit signal in a SIEM is where detection happens.** `MailItemsAccessed`, inbox-rule creation, privileged role adds, app consents, mass downloads, anonymous-link creation — these only become alerts when they land next to your identity, endpoint, and network telemetry and can be correlated.
- **The audit store is not a long-term archive.** Audit (Standard) retains most records ~180 days; streaming to a SIEM / data lake is how you keep audit evidence for the duration your compliance and legal functions require, independently of the audit store's retention.
- **There are several export paths and they are evolving.** The **Management Activity API** (poll or

webhook), the **Graph Audit Log Query API** (newer), and **native connectors** (e.g. Microsoft Sentinel's Office 365 / Microsoft 365 connectors, the Splunk Add-on) each have different effort, latency, and coverage profiles. Choosing right — and confirming what your tenant/licensing supports — matters more than any single cmdlet. **Verify your licensing/tenant.**

• **A pipeline you don't reconcile is a pipeline you don't trust.** The failure mode isn't "no data" —

it's *silent partial loss*: a subscription stops, a webhook expires, a content type was never subscribed, blobs age out un-collected. This solution reconciles SIEM ingestion against the source audit log so gaps surface as a gate, not as a missed detection six months later.

How it works

1. **Assess the export surface.** Read-only discovery reports whether unified audit ingestion is on,

which Management Activity API **content subscriptions** already exist, whether an app identity with the right permissions is in place, and whether a native connector is already ingesting — so you know the real starting point, not the assumed one.

1. **Choose the path.** Decide per environment: native connector (lowest effort where available),

Management Activity API (most control, push or poll), or Graph Audit Log Query API (newer, query-based). The choice is driven by your SIEM, latency needs, and tenant support — not by defaults.

1. **Stand up the identity.** For the Management Activity API, an **Entra app registration** with

`ActivityFeed.Read` (and `ActivityFeed.ReadDlp` for DLP events), admin-consented, authenticating **app-only with a certificate** — never a client secret in code.

1. **Subscribe to content, pilot-first.** Start **one** content type (typically `Audit.AzureActiveDirectory`)

in a bounded pilot, optionally with a **webhook** for push delivery, and confirm the SIEM receives blobs before expanding to the rest.

1. **Reconcile.** Compare what the SIEM ingested for a window against the source unified audit log

(`Search-UnifiedAuditLog` / Graph Audit Log Query) — record counts by workload — so any drop, lag, or missing content type is caught explicitly.

1. **Validate and expand.** A pipeline scorecard confirms every gate — ingestion on, subscriptions

enabled, delivery current, coverage per workload, reconciliation clean — then export expands to full scope and the read-only checks run on a cadence to catch drift.

The export stack this solution configures

• **Unified audit log** — the single source of user/admin activity across the M365 estate (assumed on).

• **Office 365 Management Activity API** — `manage.office.com/api/v1.0/{tenant}/activity/feed`; content

subscriptions per content type, blobs retrieved by **poll** or delivered by **webhook**; app-only cert auth with `ActivityFeed.Read` / `ActivityFeed.ReadDlp`.

• **Content types** — `Audit.AzureActiveDirectory`, `Audit.Exchange`, `Audit.SharePoint`,

`Audit.General`, `DLP.All`.

- **Microsoft Graph Audit Log Query API** — `/security/auditLog/queries` (newer, query/result model) —

an alternative retrieval path; **verify availability/GA status in your tenant**.

- **Native SIEM connectors** — e.g. **Microsoft Sentinel** Office 365 & Microsoft 365 connectors, the

Splunk Add-on for Microsoft Office 365, and vendor connectors (QRadar, Elastic) that consume the Management Activity API for you — lowest-effort where supported.

- **Delivery model** — webhook (push) vs. scheduled poll with checkpointing; both must be monitored.

What you can control

- The **export path** (native connector / Management Activity API / Graph) per environment.
- Which **content types** (workloads) stream, and in what order they are piloted then expanded.
- **Push vs. poll** delivery and the collection cadence / checkpoint.
- The **pilot scope** (one content type, a bounded window) validated before full coverage.
- The **reconciliation window and tolerance** used to prove the pipeline is lossless.

Naming convention (used in every doc and script)

Every artifact this solution creates is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal/SIEM. The standard set:

Artifact	Name
Entra app registration for the feed	`Audit Feed – Management API – AppReg`
App-only authentication certificate	`Audit Feed – App-Only – Certificate`
Entra content subscription	`Audit Export – Entra – Subscription`
Exchange content subscription	`Audit Export – Exchange – Subscription`
SharePoint content subscription	`Audit Export – SharePoint – Subscription`
General content subscription	`Audit Export – General – Subscription`
DLP content subscription	`Audit Export – DLP – Subscription`
Push-delivery webhook	`Audit Feed – Blob Notification – Webhook`
SIEM ingestion connector	`Audit Ingestion – SIEM – Connector`
Pilot validation scope	`Audit SIEM Pilot – Entra Feed – Stage1`
Source↔SIEM reconciliation report	`Audit Pipeline – Coverage – Report`
Audit-event → detection use-case map	`Audit-to-Detection – Use-Case – Map`

Limitations (be honest with buyers)

• **This is the pipeline, not the audit config.** If unified audit ingestion is off, or the events you

want (e.g. `MailItemsAccessed`, a Premium high-value event) aren't being generated, no export path can ship what was never captured — configure audit first (companion solution). **Audit is not retroactive.**

• **Export paths and their limits are licensing-/tenant-dependent and evolving.** Management Activity API

bandwidth, the availability/GA status of the Graph Audit Log Query API, and which native connectors are offered vary by plan and change over time — **verify your licensing/tenant** before standardizing.

• **The Management Activity API is near-real-time, not instant.** Content is published in blobs with

inherent latency (typically minutes, can be longer under load); it is an activity feed, not a live tap.

• **SIEM-side ingestion, parsing, and cost are yours.** This solution delivers the source feed and proves

it flows; the connector configuration, field parsing, detection rules, and ingestion cost inside your SIEM are owned by your SOC/SIEM team (we provide the use-case map and reconciliation, not the SIEM licence).

• **Detection content and case actions are deferred.** Which alerts to build and how to respond are SOC

determinations; **retention adequacy and any legal-hold/regulatory obligations are deferred to your compliance, records, privacy, and legal functions** — this solution provides the technical method and the evidence, not the determination.

The standard deployment model

> *Assess the current export surface → design the path, identity, and content-type coverage → configure the app, subscriptions, and delivery → **pilot** one content type end-to-end into the SIEM → validate by reconciling SIEM ingestion against the source audit log → expand to full workload coverage and schedule the drift checks. Pattern: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand.***

2. Requirements Guide — Purview Audit → SIEM Integration

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/records/legal stakeholders, pilot & change control) are in `global-requirements-purview.md` — this guide adds the **export/pipeline-specific** detail.

> ***Licensing/tenant boundary.** Export **surface** and **limits** are plan- and tenant-dependent and evolving: Management Activity API bandwidth scales with your subscription (higher with Audit Premium / E5), the **Graph Audit Log Query API** availability/GA status varies, and which **native connectors** your SIEM offers changes over time. Where this guide flags "verify your licensing/tenant," do so before relying on a path. This solution assumes **unified audit logging is already on** — see the companion Purview Audit solution to enable and configure it.*

2.1 Unified audit logging already enabled (assumed input)

Description: `UnifiedAuditLogIngestionEnabled` must be **true** for the tenant, and the events you intend to export (e.g. mailbox high-value events, DLP events) must actually be generated. This solution exports what audit captures; it does not capture it. **Why:** No export path can ship records that were never written; audit is not retroactive (GR §6). **Verify:** `Get-AdminAuditLogConfig | Format-List UnifiedAuditLogIngestionEnabled` (via `Connect-ExchangeOnline`); `AUDSIEM-Discovery.ps1` reports the state and flags it if off. **Implement:** Enable and configure audit first (companion **Purview Audit (Standard & Premium)** solution) before wiring export.

2.2 Export path decided (native connector vs. Management API vs. Graph)

Description: A decision on **how** audit will reach the SIEM: a **native connector** (e.g. Microsoft Sentinel's Office 365 / Microsoft 365 connectors, the Splunk Add-on for Microsoft Office 365, or a vendor connector for QRadar/Elastic), the raw **Office 365 Management Activity API** (most control; push or poll), or the **Microsoft Graph Audit Log Query API** (newer, query-based). **Why:** Effort, latency, coverage, and cost differ per path; picking one drives every step below. **Verify:** Confirm which connector your SIEM offers and whether it is already ingesting; confirm the Graph Audit Log Query API's availability in your tenant if you plan to use it. **Implement:** Prefer a **native connector where available** (lowest effort); use the Management Activity API when you need control the connector doesn't give, or when no connector exists. **Verify your licensing/tenant** for the Graph path before standardizing on it.

2.3 Entra app registration for the Management Activity API (if using it)

Description: An **Entra app registration** — `Audit Feed – Management API – AppReg` — with the application permission `ActivityFeed.Read` (Office 365 Management APIs), plus `ActivityFeed.ReadDlp` if you will export DLP events, **admin-consented**. **Why:** The Management Activity API authorizes per app identity; without the granted+consented permission, subscription and content calls fail with authorization errors (GR §2). **Verify:** Entra admin center → `App registrations` → `<app>` → `API permissions` shows the `ActivityFeed.*` application permissions **granted for the tenant**; `AUDSIEM-Discovery.ps1` (read-only) can list current subscriptions with the app to prove auth works. **Implement:** Register the app, add the Office 365 Management APIs → Application permissions `ActivityFeed.Read` (`ActivityFeed.ReadDlp` for DLP), and grant admin consent — under change control.

2.4 Certificate app-only authentication (no secrets in code)

Description: The app authenticates **app-only with a certificate** — `Audit Feed – App-Only – Certificate` — uploaded to the app registration, private key available on the run host by thumbprint. **No client secret is stored in scripts. Why:** Certificate credentials avoid a long-lived secret in code/config and are the supported app-only pattern; this solution's rule (and GR) is **never hardcode credentials/secrets**. **Verify:** The certificate's public key is on the app registration (`Certificates & secrets`), and `Get-Item Cert:\CurrentUser\My\<thumbprint>` (or LocalMachine) returns it with a private key on the run host. **Implement:** Create/obtain a certificate, upload the `.cer` to the app, install the private key on the collection host, and record the thumbprint (not the key) in your runbook.

2.5 Export/read roles (least-privilege)

Description: The identities involved need least-privilege roles: the **app** needs only the `ActivityFeed.*` application permission (2.3); the **admin** running reconciliation needs **View-Only Audit Logs / Audit Logs**

(or the Purview **Audit Reader** role group) to run `Search-UnifiedAuditLog` / the Graph query for the source-of-truth comparison; and configuring the app/consent needs the appropriate Entra admin role. Reserve Global Administrator for consent/registration only. **Why:** Purview and Entra both use fine-grained roles; over-granting the app or the operator is an unnecessary risk (GR §2). **Verify:** App shows only `ActivityFeed.*`; the reconciliation admin can run `Search-UnifiedAuditLog`; `AUDSIEM-Reconcile.ps1` reports a permissions error if the audit-read role is missing. **Implement:** Grant the app only `ActivityFeed.*`; assign the operator **Audit Reader** and the least Entra role needed for app management, under change control.

2.6 SIEM ingestion endpoint and its identity

Description: The **SIEM/target** that will ingest the feed (Microsoft Sentinel, Splunk, QRadar, Elastic, a data lake, …) with a defined ingestion endpoint — for **webhook push** an HTTPS endpoint the Management Activity API can reach (that will pass the API's **validation handshake**), or for **poll** a collector (connector/add-on/scheduled job) that retrieves and forwards blobs. **Why:** Export is only useful if something ingests it; webhook and poll each have setup and monitoring requirements. **Verify:** The SIEM connector/collector is identified and reachable; for webhook, the endpoint answers the validation POST; `AUDSIEM-Validate.ps1` can enumerate available content blobs the collector should be consuming. **Implement:** Stand up the SIEM connector/collector (native connector, Splunk Add-on, or your own webhook receiver) and confirm reachability before starting subscriptions.

2.7 Detection use-cases and retention target (from SOC / compliance)

Description: A short statement — from your **SOC** and **compliance/records/legal** functions — of the **detection use-cases** the export must support (which audit events map to which alerts) and **how long** audit must be retained in the SIEM/lake beyond the audit store. **Why:** These are governance/SOC determinations, not technical defaults (GR §5): they decide which content types matter most and drive the `Audit-to-Detection – Use-Case – Map` and retention config — the solution configures to them, it does not decide them. **Verify:** You can name the priority detection use-cases and the required SIEM-side retention, with owners. **Implement:** Capture the use-case map and retention target with named approvers before expanding coverage.

2.8 A pilot scope and change window

Description: A limited **pilot** — typically **one content type** (`Audit.AzureActiveDirectory`) over a bounded window — to validate end-to-end delivery and reconciliation before enabling all content types, plus an agreed change window (GR §6). **Why:** Starting subscriptions and (especially) webhook delivery is tenant-impacting and can generate volume/cost; validate one path small first. **Verify:** A named pilot scope (`Audit SIEM Pilot – Entra Feed – Stage1`) and change approval exist. **Implement:** Define the pilot content type, reconciliation window, and change window before starting any subscription.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

Vendor boundary (applies to every Purview solution). *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are in preview) and the portal is* ***actively evolving*** *— capability availability and portal paths are* ***cited or flagged "verify your licensing/tenant"****, never asserted or invented.* ***Regulatory, records-retention, and legal determinations*** *(retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are* ***deferred to the organization's compliance, records, privacy, and legal functions*** *— the solutions provide the technical configuration method and evidence, not the determination. Automation is* ***PowerShell*** *(Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Purview Audit → SIEM Integration

Follow these steps **in order**. Configuration uses the **Microsoft Purview / Entra portals**, **Exchange Online / Security & Compliance PowerShell** (`Connect-ExchangeOnline`, `Connect-IPPSSession` — for the source-of-truth `Search-UnifiedAuditLog`), **Microsoft Graph** (licensing + the Audit Log Query API), and the **Office 365 Management Activity API** (`manage.office.com/api/v1.0/{tenant}/activity/feed`). Every write is gated: scripts run **read-only or** `-WhatIf` **by default** and only change state with `-Commit`. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **App-only auth is certificate-based — no secrets in code.**

> ***Model:*** *Assess the export surface you have, design the path/identity/coverage, configure the app and subscriptions,* ***pilot*** *one content type end-to-end into the SIEM, validate by* ***reconciling*** *SIEM ingestion against the source audit log, then expand. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot*** *→* ***Validate*** *→* ***Expand.*** *Getting audit into the SIEM *reliably* is the goal — a feed you haven't reconciled is a feed you can't trust.*

Step 1 — Assess the current export surface (Assess)

1. Run `AUDSIEM-Discovery.ps1` (read-only). It connects to Exchange Online, Graph, and — with the app

certificate — the Management Activity API, and reports:

• `UnifiedAuditLogIngestionEnabled` (is the source on at all? — Requirement 2.1),

• existing **Management Activity API content subscriptions** and their `status`,

• whether the app identity (`Audit Feed – Management API – AppReg`) authenticates and carries `ActivityFeed.*`,

• whether a **native connector** is already ingesting (recorded from your SIEM — the script prompts you to confirm), so you don't double-subscribe.

1. In the SIEM, note any existing Office 365 / M365 audit ingestion (a native connector may already cover

part of this). **Do not** stand up a duplicate feed for a content type a connector already ingests.

1. Record the gaps: ingestion off, no app identity, no subscriptions, no connector, partial coverage.

Pass gate: a written current-state for each item.

Step 2 — Choose the export path and design coverage (Design)

1. Decide the path per Requirement 2.2:

• **Native connector** (recommended where available) — e.g. Microsoft Sentinel's **Office 365** and **Microsoft 365** connectors, or the **Splunk Add-on for Microsoft Office 365**. Lowest effort; the connector manages subscriptions/collection for you.

• **Management Activity API** — when you need control a connector doesn't give, or none exists. Push

(**webhook**) or **poll** delivery. This solution's helper manages the subscriptions.

• **Graph Audit Log Query API** (`/security/auditLog/queries`) — newer, query/result model; **verify

availability/GA in your tenant** before standardizing.

1. Map **content types** → **detection use-cases** with your SOC (Requirement 2.7) as `Audit-to-Detection –

Use-Case – Map, e.g. Audit.AzureActiveDirectory → risky sign-in / role-change / app-consent detections; Audit.Exchange → mailbox-compromise (inbox rules, MailItemsAccessed); Audit.SharePoint → mass download / external sharing; DLP.All` → policy-match alerting.

1. Define the **pilot** `Audit SIEM Pilot – Entra Feed – Stage1` (one content type, a bounded reconciliation

window) and the SIEM-side retention target. **Pass gate:** path, use-case map, pilot, and retention are documented and approved.

Step 3 — Stand up the app identity (Configure)

(Skip if using only a native connector that authenticates itself — go to Step 6.)

1. Register `Audit Feed – Management API – AppReg` in Entra; add **Office 365 Management APIs →

Application permissions `ActivityFeed.Read` **(add** `ActivityFeed.ReadDlp` **if exporting DLP), and** grant admin consent** (Requirement 2.3) — under change control.

1. Create/obtain the certificate `Audit Feed – App-Only – Certificate`, upload the `.cer` to the app, and

install the private key on the collection host; record the **thumbprint** (not the key) — Requirement 2.4.

1. **Pass gate:** `AUDSIEM-Discovery.ps1` authenticates app-only with the certificate and lists

subscriptions (empty is fine) — proving identity + permission + consent work. **Rollback:** removing the app/consent is non-destructive to audit data (the source log is untouched).

Step 4 — Start the pilot content subscription (Configure → Pilot)

1. Preview the pilot subscription (no change made):

`AUDSIEM-Configure-Subscription.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -ContentType Audit.AzureActiveDirectory -Action Start -WhatIf` — prints the exact `POST .../subscriptions/start?contentType=Audit.AzureActiveDirectory` it would run.

1. **If push delivery:** re-run with `-WebhookAddress https://<your-endpoint>` — the script includes the

webhook body (`address`, `authId`, `expiration`) so the API performs its **validation handshake** against your endpoint (`Audit Feed – Blob Notification – Webhook`). Your endpoint MUST answer the validation POST. **If poll delivery:** omit the webhook; your collector will call `subscriptions/content` on

a cadence.

1. Commit the pilot: re-run with `-Commit`. Name it `Audit Export – Entra – Subscription`.

2. **Pass gate:** `AUDSIEM-Discovery.ps1` shows the Entra subscription `enabled`; if webhook, your endpoint

logged the validation handshake. **Rollback:** `AUDSIEM-Configure-Subscription.ps1 ... -Action Stop -Commit` (stops the subscription; the source audit log is unaffected).

Step 5 — Confirm blobs are flowing to the SIEM (Pilot)

1. Generate benign in-scope activity (e.g. a test sign-in / role change for `Audit.AzureActiveDirectory`),

wait for feed latency (minutes), then run `AUDSIEM-Validate.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -ContentType Audit.AzureActiveDirectory -Hours 1` — it lists **available content blobs** for the window and their counts (read-only).

1. Confirm the **SIEM ingested** those same events (search the SIEM for the test activity). If blobs are

available at the API but absent in the SIEM, the gap is **collection/connector-side** (webhook not reachable, collector not polling, parsing dropped them) — not the subscription.

1. **Pass gate:** the pilot content type's events are visible **in the SIEM**, end to end.

Step 6 — Reconcile SIEM ingestion against the source (Validate)

1. Run `AUDSIEM-Reconcile.ps1 -ContentType Audit.AzureActiveDirectory -Hours 24` — it counts source records

for the window via `Search-UnifiedAuditLog` (and/or the Graph Audit Log Query API) by workload and prints the expected volume to compare against your SIEM's ingested count for the same window (`Audit Pipeline – Coverage – Report`).

1. Compare: source count vs. SIEM count for the window, within an agreed tolerance (feed latency means the

very newest minutes may lag — align the window to allow for it). A material shortfall = **silent loss** to investigate (stopped subscription, expired webhook, un-collected blobs, connector filter).

1. **Pass gate:** SIEM ingestion matches the source within tolerance for the pilot content type. Complete the

Testing Guide before expanding.

Step 7 — Expand to full workload coverage (Expand)

1. With the pilot reconciled clean, start the remaining designed content types, each previewed then

committed — `Audit Export – Exchange – Subscription`, `Audit Export – SharePoint – Subscription`, `Audit Export – General – Subscription`, and (if licensed/needed) `Audit Export – DLP – Subscription` (`ActivityFeed.ReadDlp`): `AUDSIEM-Configure-Subscription.ps1 ... -ContentType Audit.Exchange -Action Start -WhatIf` → review → `-Commit`. Repeat per content type. Reconcile each (Step 6) before treating

it as trusted.

1. Confirm the SIEM parses each workload's schema and the `Audit-to-Detection – Use-Case – Map` detections

fire on test activity. Set the SIEM-side retention to the target from Requirement 2.7.

1. **Pass gate:** every in-scope content type is `enabled`, ingested, and reconciled clean; detections

validated on test activity.

Step 8 — Operationalize and monitor the pipeline (Expand)

1. Schedule the read-only chain (`AUDSIEM-Discovery.ps1` → `AUDSIEM-Report.ps1`) on a cadence so drift is

caught early: a subscription flipping to disabled, a **webhook expiring** (Management Activity API webhook subscriptions expire and must be renewed), a content type with no recent blobs, a lapsed certificate.

1. Run `AUDSIEM-Reconcile.ps1` periodically (e.g. daily) as a standing **coverage check** so partial loss

surfaces as an alert, not as a missing detection later.

1. Hand `Audit Pipeline – Coverage – Report` and the monitoring cadence to your SOC as the standing

procedure. **Pass gate:** all content types enabled tenant-wide, reconciliation scheduled and green, and the pipeline itself is monitored (feed health is a first-class alert).

5. Testing & Validation Guide — Purview Audit → SIEM Integration

Run these tests after implementation and on a cadence thereafter. Each test states **what to run**, the **pass criterion**, and the **fail action**. Tests use the safe-by-default scripts (read-only or `-WhatIf`) and confirm the pipeline is not just configured but **lossless end to end**. Do not expand coverage until the pilot content type passes every gate.

Test 1 — Source is on (precondition)

- **Run:** `AUDSIEM-Discovery.ps1` and read `UnifiedAuditLogIngestionEnabled`.
- **Pass:** ingestion is `True` and the events you intend to export are being generated.
- **Fail:** if `False`, stop — no export path can ship what audit isn't capturing. Enable/configure audit

first (companion Purview Audit solution). Audit is not retroactive.

Test 2 — App identity authenticates app-only

- **Run:** `AUDSIEM-Discovery.ps1` (which lists subscriptions with the app certificate).
- **Pass:** the call authenticates and returns the subscription list (empty is acceptable pre-config),

proving app registration + `ActivityFeed.*` permission + admin consent + certificate all work.

- **Fail:** an auth/permission error means the permission isn't granted/consented, or the certificate/key is missing on the host — fix Requirements 2.3/2.4, not the script.

Test 3 — Pilot subscription is enabled

- **Run:** `AUDSIEM-Discovery.ps1` after Step 4.
- **Pass:** `Audit Export – Entra – Subscription` shows `status = enabled`.
- **Fail:** re-run `AUDSIEM-Configure-Subscription.ps1 ... -Action Start -Commit`; if it errors on bandwidth/availability, **verify your licensing/tenant** (Management Activity API limits scale with plan).

Test 4 — Webhook validation handshake (push delivery only)

- **Run:** start the subscription with `-WebhookAddress`; watch your endpoint's logs.
- **Pass:** your endpoint received and correctly answered the API's **validation POST**, and the subscription is `enabled` with the webhook attached.
- **Fail:** if validation failed, the endpoint isn't reachable/answering correctly — fix the receiver, then re-start. Remember webhook subscriptions **expire and must be renewed** (Step 8 monitoring catches this).

Test 5 — Blobs available at the API for benign test activity

- **Run:** generate benign in-scope activity, wait for latency, then `AUDSIEM-Validate.ps1 -ContentType Audit.AzureActiveDirectory -Hours 1`.
- **Pass:** the window lists content blobs with a non-zero count covering the test activity.
- **Fail:** if zero after allowing for latency, confirm the activity actually generated audit records (Test 1) and that the correct content type was subscribed.

Test 6 — End-to-end: events land in the SIEM

- **Run:** search the SIEM for the same benign test activity.
- **Pass:** the events are present **in the SIEM**, correctly parsed into the expected fields.
- **Fail:** blobs available at the API but missing in the SIEM ⇒ collection/connector-side issue (webhook unreachable, collector not polling, parser dropped them) — fix the ingestion side, not the subscription.

Test 7 — Reconciliation: no silent loss

- **Run:** `AUDSIEM-Reconcile.ps1 -ContentType Audit.AzureActiveDirectory -Hours 24` and compare the source

count to the SIEM's ingested count for the same aligned window.

- **Pass:** SIEM ingestion matches the source within the agreed tolerance (allowing for feed latency on the

newest minutes) — recorded in `Audit Pipeline – Coverage – Report`.

- **Fail:** a material shortfall = silent partial loss; investigate a stopped subscription, expired webhook,

un-collected blobs, or a connector filter. Do **not** declare the pipeline trusted until it reconciles.

Test 8 — Detection use-cases fire

- **Run:** trigger a benign test for a mapped use-case (e.g. a test role add for the role-change detection)

and confirm the SIEM detection fires per `Audit-to-Detection – Use-Case – Map`.

- **Pass:** the detection triggers on the test activity within expected latency.

- **Fail:** confirm the event reached the SIEM (Test 6) before debugging the rule — a missing detection is

usually a missing event, not a bad rule.

Test 9 — Full-coverage regression (after Expand)

- **Run:** `AUDSIEM-Report.ps1` for a tenant-wide pipeline scorecard, then `AUDSIEM-Reconcile.ps1` per

content type.

- **Pass:** every in-scope content type is `enabled`, delivering recent blobs, and reconciling clean; no

content type is dark.

- **Fail:** any disabled/lagging/short content type is a coverage gap — remediate before relying on it for

detection or retention.

Test 10 — Drift check (scheduled)

- **Run:** the scheduled `AUDSIEM-Discovery.ps1` → `AUDSIEM-Report.ps1` → `AUDSIEM-Reconcile.ps1` chain.

- **Pass:** no change from the validated baseline — subscriptions enabled, webhook current, certificate

valid, reconciliation within tolerance.

- **Fail:** any drift (a stopped subscription, an expired webhook, a lapsed certificate, a reconciliation

shortfall) raises an alert and is remediated under change control. **Pipeline health is a first-class alert** — a dark feed is a blind SOC.

6. Troubleshooting — Purview Audit → SIEM Integration

The failure modes that make an audit feed **silent, partial, or untrusted** — plus the app-identity, subscription, webhook, and reconciliation issues you'll hit getting Purview audit into a SIEM. Each: **symptom → likely cause → fix.** The recurring lesson: *a feed you haven't reconciled is a feed you can't

trust* — most "we're missing events" reports are a stopped subscription, an expired webhook, or an un-collected blob, not lost audit data (the **source log is untouched** by any of this).

`AUDSIEM-Discovery.ps1` reports `UnifiedAuditLogIngestionEnabled = False`

- **Cause:** unified audit logging is off at the source, so there is nothing to export.
- **Fix:** enable it (Requirement 2.1) — `Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true`

via Exchange Online — under change control, and allow time for it to take effect. **Verify** whether your tenant/region already has it on by default before assuming a defect.

The app identity won't authenticate app-only

- **Cause A — consent not granted.** `ActivityFeed.Read` (and `ActivityFeed.ReadDlp` for DLP) are

Application permissions needing **admin consent**. **Fix:** grant admin consent on `Audit Feed – Management API – AppReg` (Requirement 2.3); re-run discovery to confirm the token carries the `ActivityFeed.*` roles.

- **Cause B — certificate/thumbprint mismatch.** The `.cer` uploaded to the app doesn't match the private

key on the collection host, or the wrong thumbprint was passed. **Fix:** confirm the `Audit Feed – App-Only – Certificate` thumbprint matches the installed private key (Requirement 2.4); re-upload the public cert if needed. **No secret/key ever goes in code** — thumbprint only.

- **Cause C — expired certificate. Fix:** roll the certificate, upload the new `.cer`, update the

thumbprint; the source audit log is unaffected while you do.

`subscriptions/start` fails the webhook validation handshake

- **Cause:** the Management Activity API POSTs a **validation** notification to your webhook and your

endpoint must echo it back; if it doesn't answer, the start fails.

- **Fix:** confirm `Audit Feed – Blob Notification – Webhook` is publicly reachable and returns the

validation token synchronously. Test with `AUDSIEM-Configure-Subscription.ps1 ... -WebhookAddress <url> -WhatIf` first (it prints the exact body), then `-Commit`. If push delivery can't be made reliable, use **poll** delivery (omit the webhook; the collector calls `subscriptions/content`).

Blobs are available at the API but absent in the SIEM

- **Cause:** the gap is **collection/connector-side**, not the subscription — webhook unreachable, collector

not polling, or the parser dropped the records.

- **Fix:** `AUDSIEM-Validate.ps1 ... -ContentType <type> -Hours 1` lists available content blobs for the

window (read-only). If blobs exist there but not in the SIEM, fix the collector/connector: webhook reachability, poll cadence, or the workload's schema parsing. The subscription is fine.

Reconciliation shows a material shortfall (source ■ SIEM)

- **Cause A — feed latency.** The newest minutes always lag; comparing right up to "now" understates the

SIEM. **Fix:** `AUDSIEM-Reconcile.ps1 -ContentType <type> -Hours 24` — align the window to allow for latency; the very newest minutes are expected to trail.

- **Cause B — silent loss.** A stopped subscription, an expired webhook, un-collected blobs, or a

connector filter dropped events. **Fix:** run `AUDSIEM-Discovery.ps1` to confirm the subscription is `enabled` and the webhook current; investigate the collector. Reconcile again after the fix — a shortfall outside tolerance is a **real** finding, not noise.

A native connector and a manual subscription are double-ingesting

- **Cause:** a SIEM native connector (Sentinel Office 365 / Microsoft 365, Splunk Add-on) already ingests a

content type you also subscribed to manually.

- **Fix:** discovery prompts you to confirm any native connector — **do not** stand up a duplicate feed for

a content type a connector already covers. Choose one path per content type (Requirement 2.2); stop the redundant subscription (`-Action Stop -Commit`) — the source log is unaffected.

A webhook subscription "just stopped" after working

- **Cause:** Management Activity API **webhook subscriptions expire** and must be renewed.
- **Fix:** schedule the read-only health chain (`AUDSIEM-Discovery.ps1` → `AUDSIEM-Report.ps1`) so an

expiring/expired webhook or a subscription flipping to disabled is caught as an alert; renew the subscription and re-validate. Treat **feed health as a first-class alert**.

The Graph Audit Log Query API isn't available / behaves differently

- **Cause:** `/security/auditLog/queries` is newer and its availability/GA state is **tenant-dependent**.
- **Fix: verify availability/GA in your tenant** before standardizing on it; the `Search-UnifiedAuditLog`

source-of-truth path in `AUDSIEM-Reconcile.ps1` remains the fallback. Don't assume parity across tenants.

DLP events aren't exporting

- **Cause:** DLP content needs the extra `ActivityFeed.ReadDlp` application permission and a separate

`Audit Export – DLP – Subscription`.

- **Fix:** add `ActivityFeed.ReadDlp` (admin consent), confirm DLP is licensed, then start the DLP

subscription previewed-then-committed. Verify DLP export is available on your plan.

`Connect-ExchangeOnline` / `Connect-IPPSSession` / `Connect-MgGraph` fails

- **Cause:** module not installed, or MFA/modern-auth not completed.
- **Fix:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` and `Install-Module Microsoft.Graph

-Scope CurrentUser`; complete the interactive modern-auth sign-in (Requirement 2.3). App-only automation uses the certificate + thumbprint, never a stored secret.

When to escalate beyond this solution

- **Whether a content type is *in scope* to export, and audit-retention obligations** → **compliance,

records, and legal** (this solution moves and reconciles the signal; it does not decide what must be retained or for how long).

- **SOC detection logic and use-case tuning** → your **security operations** team, using the

`Audit-to-Detection – Use-Case – Map` as the starting contract.

- **A source cmdlet/API that has genuinely changed** → verify against current Microsoft documentation;

the Management Activity API, Graph audit APIs, and connector surfaces evolve.

7. Best Practices — Purview Audit → SIEM Integration

Operating principles for a **reliable, defensible** audit-to-SIEM pipeline. They extend the category global requirements and reflect the Assess → Design → Configure → Pilot → Validate → Expand model.

Path selection

- **Prefer a native connector where one exists.** Microsoft Sentinel's Office 365 / Microsoft 365

connectors and the Splunk Add-on for Microsoft Office 365 manage subscriptions and collection for you — far less to build and monitor than the raw API. Use the **Management Activity API** directly only when you need control the connector can't give, or no connector exists.

- **Treat the Graph Audit Log Query API as evolving.** It is the newer, query-based path — **verify its

availability/GA status in your tenant** and confirm supportability before standardizing automation on it.

- **Don't double-feed a content type.** If a native connector already ingests `Audit.Exchange`, don't also

run a Management API subscription for it into the same SIEM — you'll pay twice and confuse reconciliation.

Identity & secrets

- **App-only, certificate, least-privilege.** Grant the app only `ActivityFeed.Read` (add `ActivityFeed.ReadDlp` only if exporting DLP). Authenticate with a **certificate**, never a client secret in code. Store the thumbprint in the runbook; keep the private key on the collection host only.
- **Rotate the certificate before it expires** and track its expiry as a monitored item — a lapsed cert silently kills the feed.
- **Scope the operator too.** The reconciliation operator needs only **Audit Reader** to read the source; don't run reconciliation as Global Admin.

Delivery reliability

- **Webhooks expire — renew them.** Management Activity API webhook subscriptions have an expiration; put renewal on a schedule and alert if a webhook goes stale. A webhook that silently expired is the classic "why did detections stop?" incident.
- **Checkpoint your poll.** If polling, track the last-collected blob/time so a collector restart doesn't re-ingest or skip. Handle the API's paging and `NextPageUri` fully — never assume one page is all the data.
- **Design for latency, not instantaneity.** The feed is near-real-time (minutes, sometimes longer under load). Align detections and reconciliation windows to the feed's latency; don't alert on "missing" events that are merely still in flight.
- **Handle blob retention.** Content blobs are only available for a limited window at the API — if your collector is down long enough, un-collected blobs age out and are lost. Monitor collector uptime and alert on gaps.

Reconcile, always

- **Reconcile SIEM ingestion against the source.** The dangerous failure is *silent partial loss*, not total outage. Compare source audit counts (`Search-UnifiedAuditLog` / Graph Audit Log Query) to SIEM-ingested counts per workload on a cadence, within a latency-aware tolerance. A pipeline you don't reconcile is a pipeline you can't trust.
- **Make pipeline health a first-class alert.** Alert on: a subscription flipping disabled, a webhook near expiry, a content type with no recent blobs, a certificate nearing expiry, a reconciliation shortfall. A dark feed blinds the SOC — treat it with the same urgency as a down detection.

Coverage & cost

• **Subscribe deliberately, driven by use-cases.** Map content types to detection use-cases with the SOC and

subscribe to what earns its ingestion cost. High-volume content types (SharePoint file operations) can be large — confirm the SIEM's ingestion budget before turning them on tenant-wide.

• **Pilot one content type first.** Validate the whole chain (subscribe → deliver → ingest → reconcile) on

`Audit.AzureActiveDirectory` before expanding, so you debug the pipeline once, not five times.

• **Set SIEM-side retention to the compliance target,** independent of the audit store's window — export is

how you keep audit evidence long-term. The **retention duration is a compliance/records determination**, not a technical default.

Governance & boundaries

• **Detection content is the SOC's; determinations are governance's.** This solution delivers the feed and

proves it flows; which alerts to build and how to respond are SOC decisions, and **retention adequacy, legal-hold, and regulatory obligations are deferred to compliance, records, privacy, and legal.**

• **Change-control the pipeline.** Starting/stopping subscriptions, changing delivery, and altering coverage

are tenant-impacting — do them under change control with the pilot-first discipline and a documented rollback (stop the subscription; the source audit log is never touched).

• **Document the pipeline.** Keep the path, app identity, content types, delivery model, SIEM endpoint, and

reconciliation window in the runbook so the pipeline is operable by someone other than its author.

8. Deliverables Summary — Purview Audit → SIEM Integration

What you receive

A complete, self-guided package to build and operate a **reliable audit-to-SIEM pipeline** from Microsoft Purview — export the unified audit log into your SIEM via the Office 365 Management Activity API / Graph Audit Log Query API / a native connector, piloted on one content type, validated by reconciliation against the source, then expanded — using only the Microsoft Purview / Entra portals, Exchange Online / Security & Compliance PowerShell, Microsoft Graph, and the Management Activity API.

Documents

Document	What it gives you
Solution Overview	What the pipeline delivers, the export stack (Management API, Graph query API, native connectors), the artifact naming convention, and the Assess→Design→Configure→Pilot→Validate→Expand model.
Requirements Guide	Every export/pipeline prerequisite (source-on precondition, path choice, app registration + `ActivityFeed.*`, certificate app-only auth, least-privilege roles, SIEM endpoint, use-cases/retention, pilot) with how to **verify** and **implement** — referencing the category global requirements.
Implementation Guide	Exact ordered steps: assess the surface, choose the path, stand up the app identity, start the pilot subscription (webhook or poll), confirm blobs flow to the SIEM, **reconcile** against the source, expand to full coverage, and monitor the pipeline — each object named, with pass/fail gates and rollback.
Testing & Validation Guide	Ten tests from source-on through app auth, subscription state, webhook handshake, blob availability, end-to-end SIEM ingestion, **reconciliation (no silent loss)**, detections firing, full-coverage regression, and scheduled drift checks.
Troubleshooting Guide	The common failure modes — auth/consent errors, subscription won't start, webhook validation fails, blobs missing, SIEM shortfall, reconciliation gaps, expired webhook/cert — with causes and fixes.
Best Practices	Path selection, identity/secret hygiene, delivery reliability (webhook renewal, poll checkpointing, latency), reconcile-always, coverage/cost, and governance boundaries.
Executive Summary	A one-page brief for decision-makers.

PowerShell tools (5)

All are **safe by default** — read-only or `-WhatIf` unless you pass `-Commit`. Management Activity API calls authenticate **app-only with a certificate**; **no credentials or secrets are stored in code.**

Script	Purpose	Default mode
AUDSIEM-Discovery.ps1	Assess the export surface: unified audit ingestion state, existing Management API subscriptions, app-identity auth check, and native-connector confirmation.	Read-only
AUDSIEM-Configure-Subscription.ps1	Start/stop Management Activity API content subscriptions, optionally with a push **webhook**; the only state-changing tool.	`-WhatIf` (writes only with `-Commit`)
AUDSIEM-Validate.ps1	List available content blobs and counts per content type for a window — confirm the API is publishing what the SIEM should be collecting.	Read-only
AUDSIEM-Reconcile.ps1	Count source audit records for a window (`Search-UnifiedAuditLog` / Graph Audit Log Query) by workload, to compare against the SIEM's ingested count — catch silent partial loss.	Read-only
AUDSIEM-Report.ps1	Pipeline health scorecard: ingestion on, subscriptions enabled, blob recency per content type, webhook/cert status flags — the `Audit Pipeline – Coverage – Report`.	Read-only

Outcomes

• A **chosen, documented export path** (native connector / Management Activity API / Graph) fit to your SIEM

and tenant.

• A **least-privilege app identity** (certificate app-only, `ActivityFeed.*`) where the API path is used.

• **Content subscriptions** for the in-scope workloads, piloted then expanded, delivering to the SIEM.

• **Reconciliation** proving the SIEM receives what the source recorded — no silent loss.

• **Pipeline monitoring** so a stopped subscription, expired webhook, or lapsed certificate is an alert, not

a missed detection.

Boundaries

Export surface and limits are **licensing-/tenant-dependent and evolving** — capabilities and paths are cited or flagged **"verify your licensing/tenant,"** never assumed. This solution builds the **pipeline**; enabling/configuring audit itself is the companion Purview Audit solution. **Detection content is the SOC's; retention adequacy, legal-hold, and regulatory determinations are deferred to compliance, records, privacy, and legal** — the solution provides the technical method and the evidence, not the determination.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

AUDSIEM-Configure-Subscription.ps1

Purpose: Manages Office 365 Management Activity API content subscriptions so audit data streams to a SIEM. SAFE BY DEFAULT: previews the exact API call and makes NO change unless -Commit is passed. Supports push delivery by attaching a -WebhookAddress at Start (the API performs a validation handshake against that endpoint). Authenticates app-only with a CERTIFICATE (thumbprint) — never a client secret in code. This is the ONLY state-changing tool in the set; all others are read-only. HOW TO RUN Preview starting the Entra content type (no change): powershell -File .\AUDSIEM-Configure-Subscription.ps1 -TenantId <guid> -AppId <guid> `-CertificateThumbprint <thumb> -ContentType Audit.AzureActiveDirectory -Action Start -WhatIf Start with a push webhook, then commit: .\AUDSIEM-Configure-Subscription.ps1 ... -ContentType Audit.AzureActiveDirectory -Action Start` -WebhookAddress https://your-collector.example.com/api/o365feed -Commit Stop (rollback) a content type: .\AUDSIEM-Configure-Subscription.ps1 ... -ContentType Audit.Exchange -Action Stop -Commit Requires an Entra app with Office 365 Management APIs ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, and a certificate uploaded to the app (private key on this host by thumbprint). PowerShell 5.1+/7+. EXPECTED RESULTS Under -WhatIf: prints the exact POST it would make. Under -Commit: the API confirms the subscription status (Start => enabled with webhook if supplied; Stop => disabled). Your webhook endpoint must answer the validation handshake for a push subscription to enable. .NOTES Purview category — Audit → SIEM integration. Certificate app-only auth; NO secrets in code. Resource is https://manage.office.com. Webhook subscriptions EXPIRE and must be renewed (monitor per the Testing Guide). Prefer a native connector where available. ContentType: Audit.AzureActiveDirectory, Audit.Exchange, Audit.SharePoint, Audit.General, DLP.All. Verify licensing/tenant for API bandwidth/availability. > [CmdletBinding()] param([Parameter(Mandatory)][string]$TenantId, [Parameter(Mandatory)][string]$AppId, [Parameter(Mandatory)][string]$CertificateThumbprint, [Parameter(Mandatory)] [ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [ValidateSet('Start','Stop')][string]$Action = 'Start', [string]$WebhookAddress, [string]$WebhookAuthId = "AUDSIEM-$([guid]::NewGuid().ToString('N').Substring(0,8))", [switch]$WhatIf, [switch]$Commit)

How to run: Preview starting the Entra content type (no change): powershell -File .\AUDSIEM-Configure-Subscription.ps1 -TenantId <guid> -AppId <guid> `-CertificateThumbprint <thumb> -ContentType Audit.AzureActiveDirectory -Action Start -WhatIf Start with a push webhook, then commit: .\AUDSIEM-Configure-Subscription.ps1 ... -ContentType Audit.AzureActiveDirectory -Action Start` -WebhookAddress https://your-collector.example.com/api/o365feed -Commit Stop (rollback) a content type: .\AUDSIEM-Configure-Subscription.ps1 ... -ContentType Audit.Exchange -Action Stop -Commit Requires an Entra app with Office 365 Management APIs ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, and a certificate uploaded to the app (private key on this host by thumbprint). PowerShell 5.1+/7+. EXPECTED RESULTS Under -WhatIf: prints the exact POST it would make. Under -Commit: the API confirms the subscription status (Start => enabled with webhook if supplied; Stop => disabled). Your webhook endpoint must answer the validation handshake for a push subscription to enable. .NOTES Purview category — Audit → SIEM integration. Certificate app-only auth; NO secrets in

code. Resource is https://manage.office.com. Webhook subscriptions EXPIRE and must be renewed (monitor per the Testing Guide). Prefer a native connector where available. ContentType: Audit.AzureActiveDirectory, Audit.Exchange, Audit.SharePoint, Audit.General, DLP.All. Verify licensing/tenant for API bandwidth/availability. > [CmdletBinding()] param([Parameter(Mandatory)][string]$TenantId, [Parameter(Mandatory)][string]$AppId, [Parameter(Mandatory)][string]$CertificateThumbprint, [Parameter(Mandatory)] [ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [ValidateSet('Start','Stop')][string]$Action = 'Start', [string]$WebhookAddress, [string]$WebhookAuthId = "AUDSIEM-$([guid]::NewGuid().ToString('N').Substring(0,8))", [switch]$WhatIf, [switch]$Commit)

AUDSIEM-Discovery.ps1

Purpose: Read-only assessment of the audit export pipeline: reports whether unified audit ingestion is on (the source precondition), which Office 365 Management Activity API content subscriptions exist and their status, and whether the app identity authenticates app-only with its certificate and carries ActivityFeed access. Makes NO changes. Prompts you to confirm any existing native SIEM connector so you don't stand up a duplicate feed. HOW TO RUN Full surface (source state via Exchange Online + subscriptions via the Management API): powershell -File .\AUDSIEM-Discovery.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> Source state only (skip the Management API app check): .\AUDSIEM-Discovery.ps1 -SkipManagementApi Requires ExchangeOnlineManagement (Connect-ExchangeOnline) for the source-on check, and — for the subscription/app check — an Entra app registration with Office 365 Management APIs ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, authenticating with a certificate (private key on this host by thumbprint). PowerShell 5.1+/7+. EXPECTED RESULTS Prints: UnifiedAuditLogIngestionEnabled (pass=True), the list of content subscriptions with status, and whether app-only auth succeeds. Any gap (ingestion off, no subscriptions, auth failure) is flagged as a finding to remediate. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Management Activity API resource is https://manage.office.com. Content types: Audit.AzureActiveDirectory, Audit.Exchange, Audit.SharePoint, Audit.General, DLP.All. Verify licensing/tenant for API bandwidth. > [CmdletBinding()] param([string]$TenantId, [string]$AppId, [string]$CertificateThumbprint, [switch]$SkipManagementApi, [switch]$SkipExchange)

How to run: Full surface (source state via Exchange Online + subscriptions via the Management API): powershell -File .\AUDSIEM-Discovery.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> Source state only (skip the Management API app check): .\AUDSIEM-Discovery.ps1 -SkipManagementApi Requires ExchangeOnlineManagement (Connect-ExchangeOnline) for the source-on check, and — for the subscription/app check — an Entra app registration with Office 365 Management APIs ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, authenticating with a certificate (private key on this host by thumbprint). PowerShell 5.1+/7+. EXPECTED RESULTS Prints: UnifiedAuditLogIngestionEnabled (pass=True), the list of content subscriptions with status, and whether app-only auth succeeds. Any gap (ingestion off, no subscriptions, auth failure) is flagged as a finding to remediate. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Management Activity API resource is https://manage.office.com. Content types: Audit.AzureActiveDirectory, Audit.Exchange, Audit.SharePoint, Audit.General, DLP.All. Verify licensing/tenant for API bandwidth. > [CmdletBinding()] param([string]$TenantId, [string]$AppId, [string]$CertificateThumbprint, [switch]$SkipManagementApi, [switch]$SkipExchange)

AUDSIEM-Reconcile.ps1

Purpose: Produces the SOURCE-OF-TRUTH audit record count for a time window, broken down by workload/record type, using Search-UnifiedAuditLog (Exchange Online). You compare this to your SIEM's ingested count for the SAME aligned window to detect SILENT PARTIAL LOSS (a stopped subscription, expired webhook, un-collected blobs, or a connector filter). Read-only — makes NO changes. This is the reconciliation gate that turns "the feed is configured" into "the feed is trusted." HOW TO RUN Source counts by record type for the last 24h (all workloads): powershell -File .\AUDSIEM-Reconcile.ps1 -Hours 24 Narrow to the content type you piloted (maps to record types for that workload): .\AUDSIEM-Reconcile.ps1 -ContentType Audit.AzureActiveDirectory -Hours 24 Requires ExchangeOnlineManagement (Connect-ExchangeOnline) and the View-Only Audit Logs / Audit Logs role (Purview Audit Reader). PowerShell 5.1+/7+. EXPECTED RESULTS Prints total source records and a per-record-type breakdown for the window. Compare to the SIEM's count for the same window within an agreed, latency-aware tolerance. A material shortfall in the SIEM = silent loss to investigate. Match within tolerance = the pipeline is lossless for that window. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Search-UnifiedAuditLog has result/throttle limits — keep windows short and page with -SessionCommand ReturnLargeSet. Feed latency means the newest minutes may not yet be in the SIEM; align the window to allow for it. The newer Graph Audit Log Query API (/security/auditLog/queries) is an alternative source — verify its availability in your tenant. > [CmdletBinding()] param([ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [ValidateRange(1,168)][int]$Hours = 24, [int]$ResultSize = 5000)

How to run: Source counts by record type for the last 24h (all workloads): powershell -File .\AUDSIEM-Reconcile.ps1 -Hours 24 Narrow to the content type you piloted (maps to record types for that workload): .\AUDSIEM-Reconcile.ps1 -ContentType Audit.AzureActiveDirectory -Hours 24 Requires ExchangeOnlineManagement (Connect-ExchangeOnline) and the View-Only Audit Logs / Audit Logs role (Purview Audit Reader). PowerShell 5.1+/7+. EXPECTED RESULTS Prints total source records and a per-record-type breakdown for the window. Compare to the SIEM's count for the same window within an agreed, latency-aware tolerance. A material shortfall in the SIEM = silent loss to investigate. Match within tolerance = the pipeline is lossless for that window. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Search-UnifiedAuditLog has result/throttle limits — keep windows short and page with -SessionCommand ReturnLargeSet. Feed latency means the newest minutes may not yet be in the SIEM; align the window to allow for it. The newer Graph Audit Log Query API (/security/auditLog/queries) is an alternative source — verify its availability in your tenant. > [CmdletBinding()] param([ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [ValidateRange(1,168)][int]$Hours = 24, [int]$ResultSize = 5000)

AUDSIEM-Report.ps1

Purpose: Produces the 'Audit Pipeline - Coverage - Report': a read-only scorecard of the export pipeline's health across concrete gates — unified audit ingestion on (source), each Management Activity API content subscription enabled, recent blob delivery per content type, webhook attached where expected, and the app certificate's expiry. Makes NO changes. Schedule it (with AUDSIEM-Discovery/Reconcile) so drift — a stopped subscription, an expired webhook, a lapsing certificate, a dark content type — surfaces as an alert rather than a missed detection. HOW TO RUN powershell -File .\AUDSIEM-Report.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> Skip the Exchange Online source check (subscriptions/cert only): .\AUDSIEM-Report.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -SkipExchange Requires the Entra app with ActivityFeed.Read (ActivityFeed.ReadDlp for DLP),

admin-consented, the certificate on this host, and (for the source gate) ExchangeOnlineManagement. PowerShell 5.1+/7+. EXPECTED RESULTS A PASS/FAIL/WARN line per gate and an overall verdict. All PASS = the pipeline is healthy for the checked content types. Any FAIL/WARN (subscription disabled, no recent blobs, cert near expiry) is a pipeline-health finding to remediate under change control. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Resource is https://manage.office.com. Pipeline health is a first-class alert — a dark feed blinds the SOC. Webhook subscriptions expire and must be renewed. Verify licensing/tenant for API bandwidth/availability. > [CmdletBinding()] param([Parameter(Mandatory)][string]$TenantId, [Parameter(Mandatory)][string]$AppId, [Parameter(Mandatory)][string]$CertificateThumbprint, [string[]]$ExpectedContentTypes = @('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General'), [int]$RecentBlobHours = 2, [int]$CertWarnDays = 30, [switch]$SkipExchange)

How to run: powershell -File .\AUDSIEM-Report.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> Skip the Exchange Online source check (subscriptions/cert only): .\AUDSIEM-Report.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -SkipExchange Requires the Entra app with ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, the certificate on this host, and (for the source gate) ExchangeOnlineManagement. PowerShell 5.1+/7+. EXPECTED RESULTS A PASS/FAIL/WARN line per gate and an overall verdict. All PASS = the pipeline is healthy for the checked content types. Any FAIL/WARN (subscription disabled, no recent blobs, cert near expiry) is a pipeline-health finding to remediate under change control. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Resource is https://manage.office.com. Pipeline health is a first-class alert — a dark feed blinds the SOC. Webhook subscriptions expire and must be renewed. Verify licensing/tenant for API bandwidth/availability. > [CmdletBinding()] param([Parameter(Mandatory)][string]$TenantId, [Parameter(Mandatory)][string]$AppId, [Parameter(Mandatory)][string]$CertificateThumbprint, [string[]]$ExpectedContentTypes = @('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General'), [int]$RecentBlobHours = 2, [int]$CertWarnDays = 30, [switch]$SkipExchange)

AUDSIEM-Validate.ps1

Purpose: Confirms the Office 365 Management Activity API is publishing content the SIEM should be collecting: enumerates the available content blobs for a content type over a time window and (optionally) counts the records inside them. Read-only — makes NO changes. Use it after starting a subscription to prove the API side is delivering, then check the SIEM ingested the same events (end-to-end). HOW TO RUN List blobs published for the last hour for the Entra feed: powershell -File .\AUDSIEM-Validate.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> ` -ContentType Audit.AzureActiveDirectory -Hours 1 Include a record count (downloads each blob — heavier): .\AUDSIEM-Validate.ps1 ... -ContentType Audit.Exchange -Hours 6 -CountRecords Requires the Entra app with ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, and the certificate on this host. PowerShell 5.1+/7+. EXPECTED RESULTS Prints the number of content blobs available for the window (and, with -CountRecords, the total audit records). Non-zero after allowing for feed latency = the API is publishing. Zero after latency = check that the activity generated audit records and that the content type is actually subscribed. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Resource is https://manage.office.com. The feed is near-real-time (minutes) — the newest minutes may not yet be published. Content blobs are available for a limited window; a down collector loses un-collected blobs. > [CmdletBinding()] param([Parameter(Mandatory)][string]$TenantId,

[Parameter(Mandatory)][string]$AppId, [Parameter(Mandatory)][string]$CertificateThumbprint, [Parameter(Mandatory)] [ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [ValidateRange(1,168)][int]$Hours = 1, [switch]$CountRecords)

How to run: List blobs published for the last hour for the Entra feed: powershell -File .\AUDSIEM-Validate.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> ` -ContentType Audit.AzureActiveDirectory -Hours 1 Include a record count (downloads each blob — heavier): .\AUDSIEM-Validate.ps1 ... -ContentType Audit.Exchange -Hours 6 -CountRecords Requires the Entra app with ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, and the certificate on this host. PowerShell 5.1+/7+. EXPECTED RESULTS Prints the number of content blobs available for the window (and, with -CountRecords, the total audit records). Non-zero after allowing for feed latency = the API is publishing. Zero after latency = check that the activity generated audit records and that the content type is actually subscribed. .NOTES Purview category — Audit → SIEM integration. Read-only; no writes; NO secrets in code. Resource is https://manage.office.com. The feed is near-real-time (minutes) — the newest minutes may not yet be published. Content blobs are available for a limited window; a down collector loses un-collected blobs. > [CmdletBinding()] param([Parameter(Mandatory)][string]$TenantId, [Parameter(Mandatory)][string]$AppId, [Parameter(Mandatory)][string]$CertificateThumbprint, [Parameter(Mandatory)] [ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [ValidateRange(1,168)][int]$Hours = 1, [switch]$CountRecords)